

Warsaw, October 18, 2023

Decision

DKN.5131.55.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended), Article 7 § 1 and Article 60, Article 101 and Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57 § 1 letters a) and h), Article 58 § 2 letter i), Article 83 § 1 and 2, Article 83 § 4 letter a) in connection with Article 33 § 1 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2 and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by Link4 Towarzystwo Ubezpieczeń S.A. based in Warsaw (ul. Postępu 15, 02-676 Warsaw), the President of the Personal Data Protection Office, finding that Link4 Towarzystwo Ubezpieczeń S.A. based in Warsaw (ul. Postępu 15, 02-676 Warsaw) violated Article 33 § 1 of Regulation 2016/679 by failing to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach, imposes on Link4 Towarzystwo Ubezpieczeń S.A. based in Warsaw (ul. Postępu 15, 02-676 Warsaw) an administrative fine in the amount of 103,752 PLN (in words: one hundred three thousand seven hundred fifty-two zlotys).

Justification

On April 28, 2022, the President of the Personal Data Protection Office, hereinafter also referred to as the "President of UODO" or "supervisory authority", received information from a third party indicating the disclosure to her - as an unauthorized person - of a confirmation of compensation granted on May 19, 2021, which revealed personal data in the form of: first name, last name, correspondence address of the person indicated in this notification, hereinafter referred to as the "Data Subject", by Link4 Towarzystwo Ubezpieczeń S.A. based in Warsaw (ul. Postępu 15, 02-676 Warsaw), hereinafter referred to as the "Administrator" or "Company". This document, sent to the unauthorized recipient on October 28, 2021, as an attachment to an email, also contained data regarding the make and model of the car related to the damage, its registration number, and additionally indicated: policy number, claim number and its value, as well as the amount of the recognized claim. The third party, who became the unauthorized recipient of the aforementioned document, explained that she informed the Administrator about the fact of receiving a document containing someone else's data, but as she indicated - did not receive a response. In connection with the above, by letter dated April 29, 2022, the President of UODO, based on Article 58 § 1 letters a) and e) of Regulation 2016/679, requested the Administrator, among other things, to clarify whether he was aware of the occurrence of the aforementioned event, as well as whether, in connection with the aforementioned situation, an analysis of the event was conducted in terms of the risk of violation of the rights or freedoms of natural persons necessary to assess whether there was a violation of data protection resulting in the necessity to notify the President of UODO and the persons affected by the breach. This letter also included, among other things, information on the content of Article 33 § 1 and 3 of Regulation 2016/679 and the possible ways to report a personal data breach. From the response provided by the Administrator in a letter dated May 11, 2022, it follows that he was aware of the occurrence of the event in question and recorded it in the appropriate register. He also explained that: "As a result of human error, during the ongoing claims settlement process, the document confirming the compensation granted to the LINK4 Client was mistakenly attached to the correspondence. As a result of the aforementioned mistake, the document reached the Client (the Injured Party) and the claims adjuster. The error was immediately corrected and the correct document was sent." Furthermore, the Company indicated that it conducted a risk analysis related to the occurrence, and also that: "In conducting similar analyses, the Company relies on the methodology recommended on the website of the Personal Data Protection Office, ENISA,

examining in particular the scope and context of data processing, the ease of identification of the person to whom the data relates, and the circumstances of the breach, which have an additional impact on the severity of the breach. It was also taken into account that the person who received correspondence not addressed to her informed the administrator of this fact. In conducting the analysis, the Company additionally used the free tool available on the website (...) to assess the severity of the breach based on the aforementioned ENISA methodology." The result of the analysis conducted using this tool was made available to the President of UODO as an attachment to the Administrator's letter. The Administrator further explained that: "The result obtained in this case indicating a low risk to the rights and freedoms of the person to whom the data relates was subsequently standardly verified by the LINK4 Data Protection Officer team. In light of the result of the conducted and verified analysis, the administrator decided to record the incident, and... regarding the low risk identified for the rights and freedoms of the data subject did not qualify the incident as a breach requiring notification to the President of the Personal Data Protection Office (UODO) and individual notification to the data subject."

In the absence of a report of the personal data breach to the supervisory authority, on November 24, 2022, the President of UODO initiated ex officio administrative proceedings against the Company in this matter (reference number: DKN.5131.55.2022).

In response to the above, the Administrator described (in a letter dated December 5, 2022) how they assessed the risk associated with the personal data breach that occurred. As stated, they were guided by the recommendations regarding methods for assessing the severity of personal data breaches in accordance with the methodology of the European Union Agency for Cybersecurity (ENISA) and Recital 76 of Regulation 2016/679, which mandates consideration of the severity of the incident, i.e., the extent of damage that the incident may cause to the data subject and the likelihood of occurrence of an event resulting from the breach.

They noted that in conducting the aforementioned assessment, they took into account not only the factual circumstances but also the potential negative consequences and the probability of their materialization. The Administrator also stated that in assessing the incident in question, they additionally used a breach severity assessment calculator, the results of which were attached to previous correspondence. The course of the analysis conducted by the Company regarding the aforementioned risk will be recounted later in this decision's justification to avoid unnecessary repetition. It should only be pointed out here that the Company, summarizing the extensive argumentation, stated that: "In this case - in accordance with the factual circumstances described above and the risk analysis conducted - the assessment of risk as low allowed for the non-reporting of the breach, as the scope of data clearly indicated the absence of any possibility of actual negative consequences for the data subject. Additionally, the broadly considered circumstances of the breach did not in any way prompt the administrator to elevate the severity level to one requiring notification. Thus, recognizing the risk as low and seeing no justification for raising this level, the administrator limited themselves to recording the incident in the incident register."

After reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:

According to Article 4(12) of Regulation 2016/679, "a personal data breach" means a security breach leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

Article 33(1) and (3) of Regulation 2016/679 states that in the case of a personal data breach, the administrator shall without undue delay - where feasible, no later than 72 hours after becoming aware of the breach - notify the supervisory authority competent under Article 55, unless it is unlikely that the breach will result in a risk to the rights or freedoms of natural persons. Any notification submitted to the supervisory authority after 72 hours shall include an explanation of the reasons for the delay. The notification referred to in paragraph 1 must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects concerned, as well

as the categories and approximate number of personal data records concerned; b) contain the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the possible consequences of the personal data breach; d) describe the measures taken or proposed by the administrator to address the personal data breach, including, where appropriate, measures to mitigate its possible negative effects.

Beginning the analysis of this matter, it should be noted that the President of UODO in the publication titled "Obligations of Administrators Related to Personal Data Breaches" (available at: <https://archiwum.uodo.gov.pl/pl/134/1029>) explains: "Depending on the level of risk to the rights and freedoms of natural persons that the administrator is dealing with, their obligations towards the supervisory authority and the data subjects differ. If, as a result of the analysis, the administrator determines that the likelihood of risk to the rights and freedoms of natural persons is low, they are not obliged to report the breach to the President of the Personal Data Protection Office. The indicated breach must only be recorded in the internal breach register. In the case of identifying a risk to the rights and freedoms of natural persons, the administrator is obliged to notify the personal data breach to the President of UODO, as well as to make an entry in the internal breach register."

As follows from the above, in the event of the administrator detecting a personal data breach, it is first necessary to conduct an analysis regarding the occurrence of a risk to the rights or freedoms of natural persons. The administrator is exempt from the obligation to notify the supervisory authority of the breach if, as a result of the conducted investigation, it turns out that there is at most a low probability of the occurrence of a risk to the rights or freedoms of natural persons. However, it should be borne in mind that the supervisory authority may request the administrator to justify the decision not to report the breach, and therefore the conclusions...

from the conducted analysis, it should be noted in the internal record of breaches. It is worth recalling that in the WP250 Guidelines[1] and in the Guidelines 9/2022[2], there are recommendations from the Working Party Art. 29 and the European Data Protection Board (hereinafter: "EDPB") regarding the requirement to report personal data breaches to the supervisory authority.

It should be emphasized that the assessment of the risk of infringement of the rights or freedoms of a natural person should be made from the perspective of the data subject, not the interests of the data controller. The failure to report a personal data breach deprives the supervisory authority of the opportunity to respond appropriately to the personal data breach, which is manifested not only in the assessment of the risk of infringement of the rights or freedoms of the data subject but also, in particular, in verifying whether the controller has taken appropriate measures to remedy the breach and minimize the negative effects for the data subjects, as well as whether appropriate security measures have been implemented to minimize the risk of a recurrence of the breach. In the analyzed factual situation, the Company's reporting of the personal data breach of the Data Subject along with the indication of the circumstances of its occurrence—in a situation where it is necessary to indicate the measures that would minimize the risk of similar breaches in the future—could prompt it to reflect on, for example, the necessity of securing data transmitted in the form of email messages (for instance, by setting a password for the transmitted files, shared through another communication channel).

Reporting personal data breaches by controllers is therefore an effective tool contributing to a real improvement in the security of personal data processing. By reporting a breach to the supervisory authority, controllers inform the President of the Personal Data Protection Office (UODO) whether, in their opinion, there is a high risk of infringement of the rights or freedoms of the data subjects and—if such a risk exists—whether they have provided relevant information to the individuals affected by the breach. The President of UODO verifies the assessment made by the controller and may—if the controller has not notified the data subjects—request such notification from them. Reporting personal data breaches allows the supervisory authority to respond appropriately, which can mitigate the effects of such breaches, as the controller has an obligation to take effective actions to ensure the protection of individuals and their personal data, which on one hand allows for the control of the effectiveness of existing solutions, and on the other hand, the assessment of modifications and improvements aimed at

preventing irregularities similar to those covered by the breach.

The very assessment of the breach conducted by the controller in terms of the risk of infringement of the rights or freedoms of natural persons is necessary to determine whether there has been a personal data breach resulting in the obligation to notify the President of UODO (Article 33(1) and (3) of Regulation 2016/679) and the individuals affected by the breach (Article 34(1) and (2) of Regulation 2016/679), should, as it should be emphasized once again, be made from the perspective of the person affected by the breach.

In a letter dated December 5, 2022, the Company described in detail the course of the risk analysis regarding the infringement of the rights or freedoms of the natural person whose data was included in the attachment to the email sent to an unauthorized recipient (and the damage liquidator). Referring to the ENISA methodology, the Company adopted three main criteria for assessment: the context of data processing, the ease of identification of the data subject, and the circumstances of the breach that have an additional impact on the severity of the breach.

In assessing the context of data processing, the Company noted that in the analyzed case, the document shared with a third party contained basic data of the natural person such as: first name, last name, mailing address, as well as information regarding the damage, such as: cost of repair and amount of compensation, information about the damaged vehicle (make, model, registration number) and information about the policy number and claim number. As emphasized by the Company, none of the transmitted data included any special categories of data nor data concerning behavior or preferences—these were ordinary data, in a relatively narrow scope, situated in a clear context of confirming the granting of compensation in the amount of (...) zlotys. In light of the above, the Company stated that besides the first name and last name and mailing address of the data subject, the third party only obtained information that damage of a specified value occurred to another person's vehicle and that as a result, this person would receive compensation in the aforementioned, objectively small amount. Considering this, the controller assessed the risk and concluded that it was not dealing with financial data. In the controller's opinion, the information about the granting of compensation in the specified amount does not practically allow for drawing any specific conclusions about the financial status of the data subject. According to the Controller, it is also impossible in this case to indicate the risk associated with obtaining loans against the detriment of the data subject, obtaining access to special categories of data, or exercising the civil rights of the natural person—similarly, the scope of data contained in the shared document does not allow for committing fraud, entering into civil law contracts to the detriment of the natural person, or using the data of the natural person for forgery. The Company also concluded that it is not possible to demonstrate that the consequence of the examined event could be a violation of good reputation.

the person whose data is concerned. In light of the above findings, the Administrator assigned a value of 1 for the context of data processing (on a four-point scale, where basic data corresponds to the number 1, behavioral data of the person: number 2, financial data: number 3, and special data: number 4).

Assessing the ease of identification, the Company concluded that the disclosed personal data was not publicly available prior to the breach, and the scope of data allowing for identification was relatively narrow. It also noted that a name and surname along with a correspondence address obviously allow for the identification of a natural person, although this requires further actions initiated by the person who received the data. Ultimately, the Administrator, adopting the perspective of the person whose data is concerned and considering the possibilities created by, for example, social media, deemed the possibility of identifying a natural person to be high and assigned a value of 1 (the highest on the scale) in this aspect.

Discussing in the letter dated December 5, 2022, the last aspect of the assessment according to the ENISA methodology, namely the circumstances of the breach that have an additional impact on the severity/seriousness of the breach, the Company indicated that these circumstances do not in themselves increase the risk of infringement of rights and freedoms, considering that the person who received the data of the injured party is a victim in another matter unrelated to the person whose data

is concerned. The Administrator indicated that in the event that the data were disclosed to another participant in the same damage, which could result in negative consequences (e.g., disclosure of the perpetrator's data to the victim or the victim's data to the perpetrator), this circumstance would be taken into account and the risk assessment for the rights and freedoms of the person whose data is concerned would be raised. The Administrator noted that the data of the natural person reached a known, narrow group of recipients (the victim in another matter and the damage liquidator) - thus, the identity of the recipients is known, and the circumstances of the case do not indicate that the recipients could have any malicious intentions regarding the use of the data of the natural person whose data was subject to the breach. Due to the breach of data confidentiality - as indicated by the Administrator - "of minor significance," a value of 0.5 was assigned in the assessment of this aspect.

After substituting the values specified by the Administrator into the formula, a result of 1.5 was obtained, which qualifies the subject breach of personal data protection as related to a low risk of infringement of the rights or freedoms of the natural person whose data was disclosed to an unauthorized person - not qualifying for reporting to the supervisory authority. The Administrator also cited the result of the analysis conducted using a tool provided by the portal (...) based also on the ENISA methodology, noting that in this case, a result of 1.75 was obtained with a "cautious and taking into account maximally inflated risk assessment criteria approach." In assessing using this tool, it was assumed that the analyzed breach concerned financial data - the Administrator noted that "(...) knowledge of the small amount of compensation awarded does not allow for conclusions about the financial situation of the person whose data is concerned, nor does its disclosure pose a risk of financial loss or any financial abuses to the detriment of the natural person."

In summary, the Administrator indicated that "In situations where it is justified by the scope of data (e.g., disclosure of the PESEL number or information about indebtedness) or context (e.g., disclosure of personal data of the victim in a traffic incident to the perpetrator of that incident), the risk is considered de facto higher than indicated by its calculation according to the ENISA methodology. In such individual cases, in the Administrator's assessment, a breach should be reported even if the risk assessment conducted according to the methodology recommended by the UODO indicates a low level. Approaching such cases with particular caution, the Administrator is guided by the welfare of the person whose data is concerned. Therefore, the Administrator reports some breaches, even when assessing the risk as low, if the disclosure of data - due to their nature, sensitivity, and quantity - may cause harm to the person whose data is concerned or when the Administrator has any doubts about the likelihood of the risk materializing for the rights and freedoms of natural persons. In deciding on the necessity of reporting or not, the Administrator assesses primarily whether the breach may result in a high risk of infringement of rights or freedoms. Even in cases where it is determined that such risk is low, the circumstances related to the scope of personal data (context of processing), ease of identification of the natural person, and any other circumstances of the breach are thoroughly analyzed. During the risk assessment for the rights and freedoms of the person whose data is concerned, the perspective of the individuals whose data are processed and have been subject to the breach is adopted. Therefore, the Administrator, despite a low risk assessment for rights and freedoms, reports to the President of the UODO breaches concerning the disclosure of documentation containing the PESEL number or information about indebtedness, even with a narrow overall scope of personal data. This is not only related to taking into account the recommendations of the supervisory authority but also to adopting the perspective of the person whose data is concerned, who may have concerns about the threatening use of personal data.

In the present case - according to the factual state described above and the risk analysis conducted - the assessment of risk as low allowed for not reporting the breach, as the scope of data clearly indicated the absence of any possibility of actual negative consequences for the person whose data is concerned. Also, the broadly considered circumstances of the breach in no way prompted the Administrator to raise the level of the breach to one requiring reporting. Thus, considering the risk as low and not seeing justification for raising this level, the administrator limited himself to recording the incident in the incident register."

In the letter from the Company dated December 5, 2022, it was also requested (quote: "if necessary, in order to directly clarify the above in connection with Article 75 of the Code of Administrative Procedure") to hear the witness, Mr. (...) - the Company's Data Protection Officer; however, the supervisory authority deemed that due to the extensive and exhaustive nature of the explanations regarding the circumstances described by the Company in the letter dated December 5, 2022, there was no such need.

When assessing the Company's position, it should first be noted that between situations where there is a low probability that a personal data breach would result in a risk to the rights or freedoms of natural persons (which usually justifies the lack of an information obligation under Article 33(1) of Regulation 2016/679) and situations where there is a high risk of infringement of the rights or freedoms of natural persons (where, in addition to the obligation under Article 33(1) of Regulation 2016/679, an additional obligation under Article 34(1) of that regulation most often arises), there are "intermediate" cases whose existence cannot be overlooked. In such cases (as indicated on page 4 of this Decision), merely recording the breach in the administrator's breach register is usually insufficient.

Article 33(1) of Regulation 2016/679 does not contain a list of cases in which reporting a personal data breach to the supervisory authority is an obligation of the administrators. This is a deliberate measure, allowing these entities to make a thoughtful decision regarding the final assessment of the potential consequences of such a breach. This freedom allows for the necessary flexibility - it is impossible to predict all possible cases of breaches in advance, let alone all cases in which the probability that they will result in a risk to the rights or freedoms of natural persons is greater than low. This lack of "automation" resulting from the absence of a closed catalog of cases in which the information obligation under Article 33(1) of Regulation 2016/679 is activated, however, sometimes leads to errors on the part of the administrators. The methodology applied by the Administrator in this case (ENISA) is one of many that an administrator can use to assess the risk of infringement of the rights or freedoms of natural persons related to the occurrence of a personal data breach, and the President of the UODO does not impose the use of any of them. It should be emphasized that due to the specificity of the matter being assessed with its help, this method requires the administrator to estimate the values adopted before incorporating them into the formula - unfortunately, in this regard, errors in assessment, underestimation, or adopting too "optimistic" assumptions often occur. Therefore, the assessment made based on this methodology (just as in the case of using any other tool facilitating the estimation of the aforementioned risk) should be verified by the administrator, taking into account the general principles of conducting this assessment. When applying the provisions of Regulation 2016/679, it should be borne in mind that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In the case of any doubts, e.g., regarding the fulfillment of obligations by administrators - also in situations where a personal data breach has occurred - these values should be considered first. Furthermore, when assessing the risk of infringement of the rights or freedoms of natural persons, the administrator should conduct the assessment with appropriate criticism and rationality (which, in the opinion of the supervisory authority, the Company did not do in this case).

The Company argues that the personal data that became the subject of the breach are "basic" data. It is worth pointing out here the EROD Guidelines 01/2021 on examples concerning the reporting of personal data breaches adopted on December 14, 2021, version 2.0, specifically example number 16 (mentioned Guidelines 01/2021, case no. 16, p. 33), which refers to a situation where an insurance group offering car insurance sent a proposal for a policy to an unauthorized recipient by mail, containing the first name, last name, date of birth, address of the policyholder, as well as the vehicle registration number without obscured digits, insurance rates for the current and next insurance year, and approximate annual mileage. This shipment, however, does not contain health data (Article 9 of Regulation 2016/679), payment data (bank data), or economic and financial data. In the discussed case, EROD indicated that the consequences for the affected person should be considered moderate,

as non-public information, such as the date of birth or unmasked vehicle registration numbers, as well as details regarding the increase in insurance rates, were disclosed to an unauthorized recipient. The probability of improper use of this data is assessed at a level from low to moderate. EROD also indicated that in individual cases, it cannot be completely ruled out that the letter will be posted on social media or that the policyholder will contact the unauthorized recipient, and that in such a case, the breach should be reported to the supervisory authority. The circumstances indicated in example number 16 show a significant similarity to the personal data breach analyzed within the framework of this administrative proceeding - both in terms of the scope...

disclosed data (which to some extent are identical), as well as in the aspect of the activities conducted by the administrator and the number of individuals affected by the breach. It should be noted that the possible consequences of the breach are not limited to those mentioned above and include, among others, the possibility of using the disclosed data to enter into, for example, civil law contracts, and also that the personal data in question were disclosed not only to one unauthorized person but also to the damage liquidator.

When assessing the scope of the disclosed personal data, it should also be emphasized that the Company, in its letter dated January 12, 2023 (in addition to providing further explanations regarding the methodology of its risk assessment), indicated the reasons why it considered that the address of the Data Subject disclosed to the unauthorized recipient is a correspondence address and not a residence or stay address. In this regard, it explained that this is the address used "in correspondence with the Client," which - in the opinion of the supervisory authority - does not allow for the conclusion that it is not simultaneously the address of their residence or stay.

It is worth noting that a concerning statement in the Company's argumentation appears in the letter dated December 5, 2022: "(...) the administrator, despite the low risk assessment for rights and freedoms, reports to the President of the UODO breaches concerning the disclosure of documentation containing the PESEL number or information about indebtedness, even with a narrow overall scope of personal data." In the case of a breach of confidentiality of such data - in the opinion of the supervisory authority - the risk of violating the rights or freedoms of individuals whose data are the subject of this data is generally difficult to consider as low. The supervisory authority has repeatedly pointed out the special nature of personal data in the form of the PESEL identification number in its decisions, which has also been supported by judgments issued by the Provincial Administrative Court in Warsaw.

Since the possibility of easy identification of the individual whose data was disclosed to an unauthorized recipient was not contested by the Company, it is necessary to address the Administrator's argumentation regarding the circumstances of the breach that have an additional impact on the severity/seriousness of the breach. Although the Company accepted a value of 0.5 in assessing this aspect of the breach, in the opinion of the supervisory authority, the breach should be viewed more broadly in this regard. It should be emphasized that the Administrator is an entity that bears special obligations imposed on it by the Act of September 11, 2015, on insurance and reinsurance activities (Journal of Laws of 2023, item 656, as amended). According to Article 35(1) of this Act, the insurance company and the persons employed therein, as well as the persons and entities through which the insurance company performs insurance activities, are obliged to maintain confidentiality regarding individual insurance contracts. Therefore, the disclosure of the Data Subject's data to an unauthorized recipient in the case of the Company is associated with a breach of additional obligations imposed on it by the aforementioned Act, i.e., the failure to maintain the confidentiality of the insurance contract (this aspect was not addressed in the explanations provided by the Company in this matter).

It is also worth considering that the email containing personal data was sent to an unauthorized recipient on (...) October 2021, and the information about this incident was reported to the President of the UODO by a third party six months after it occurred. This may indicate that the person possessing information about this breach did not consider it trivial and unworthy of monitoring despite the relatively long passage of time (from the information provided by them, it appears that they are wondering whether someone has received their personal data). Although the Administrator is not bound by the

opinions of third parties regarding the assessment of the risk of violation of the rights or freedoms of individuals related to the breach that occurred, it should still take into account the fact that the President of the UODO informed it in a letter dated April 29, 2022, about the content of Articles 33(1) and (3) of Regulation 2016/679 and the ways to report a breach.

In this case, the initiation of administrative proceedings by the supervisory authority regarding the failure to report the breach of personal data protection to the President of the UODO in accordance with Article 33(1) of Regulation 2016/679 did not prompt the Administrator to reflect deeply on the correctness of the risk assessment adopted in this case regarding the rights or freedoms of the individual who is the subject of the data. The Administrator also did not take into account that in the factual circumstances of this case, there was a loss of control over personal data.

It should be noted for the record that the performance by the Administrator of its obligation arising from Article 33(1) of Regulation 2016/679 cannot be conditioned on the occurrence of a breach of the rights or freedoms of individuals whose data are the subject of the breach of personal data protection. As stated by the Provincial Administrative Court in Warsaw in its judgment of September 22, 2021, in case file II SA/Wa 791/21: "It should be emphasized that the possible consequences of the event do not have to materialize. The content of Article 33(1) of Regulation 2016/679 indicates that the mere occurrence of a breach of personal data protection, which is associated with a risk of violation of the rights or freedoms of individuals, implies the obligation to report the breach to the relevant supervisory authority, unless it is unlikely that the breach will result in a risk of violation of the rights or freedoms of individuals" (and this Court similarly ruled in its judgment of July 1, 2022, in case file II SA/Wa 4143/21 and in its judgment of January 21, 2022, in case file II SA/Wa 1353/21).

It is particularly important to emphasize that when assessing the risk of violation of the rights or freedoms of individuals...

physical persons, from which, among other things, the notification of a personal data breach depends, it is necessary to take into account both the likelihood factor and the weight of potential negative consequences. A high level of either of these factors affects the overall assessment, which is necessary for fulfilling, among other obligations, the duty specified in Article 33(1) of Regulation 2016/679. Considering that, due to the scope of the disclosed personal data in the analyzed case, there was a possibility of negative consequences materializing for the data subject, the weight of the potential impact on the rights or freedoms of the individual must be regarded as greater than low. At the same time, the likelihood of risk occurring as a result of the breach in question is not small and has not been eliminated. Therefore, it should be stated that in connection with the breach in question, there was a risk of infringement of the rights or freedoms of the data subject, which consequently determines the obligation to notify the supervisory authority of the personal data breach. The Article 29 Working Party in Guidelines WP250 indicates that "(...) when assessing the risk that may arise from a breach, the controller should take into account both the weight of the potential impact on the rights and freedoms of individuals and the likelihood of its occurrence. Of course, the risk increases when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases. In case of any doubts, the controller should report the breach, even if such caution may seem excessive." It should also be noted that in connection with the occurrence of the personal data breach, there were no factors reducing the level of likelihood of negative consequences, such as limited identification possibilities, the determination that the personal data is publicly available, or the recognition of the improper recipient (at least to the extent that the recipient is a person other than the damage liquidator) as a "trusted" person. It is also worth referring here to the previously mentioned Guidelines 9/2022 - especially to Section II of these Guidelines concerning Article 33 of Regulation 2016/679 and the resulting obligation to notify the supervisory authority. In Chapter D of this section, the EDPB discussed the conditions under which such notification is not required - a thorough analysis of the content of this chapter allows us to conclude that the EDPB holds the position that the exception in Article 33(1) of Regulation 2016/679 (i.e., the case where there is no obligation to notify the supervisory authority of a personal data breach due to the low likelihood of infringement of the rights or freedoms of individuals) should be understood narrowly - in other words: as an exception that applies

in situations where this likelihood is obviously low. When discussing the issue of the “magnitude” of risk, it is also worth citing a fragment of the commentary to Article 24 of Regulation 2016/679 titled “General Data Protection Regulation. Data Protection Act. Selected Sectoral Provisions. Commentary” (ed. Dr. P. Litwiński), which states that “Regarding the level of threat, it should be assumed that under the GDPR, the risk associated with data processing can take one of two forms (levels): 1) high risk (Article 35 GDPR); 2) one that is not high risk - which can be called ordinary risk. The General Data Protection Regulation also specifies in Article 27(2)(a) in fine and Article 33(1) situations in which it is unlikely that a given data processing activity will result in a risk of infringement of the rights or freedoms of individuals. In light of these provisions, some attempt to distinguish a third category - low risk (see G. Maldoff, *The Risk-Based*, p. 2). As A. Mednis points out (A. Mednis, *Requirement*, p. 29), “it should be noted here that both provisions allowing for non-compliance with the mentioned obligations refer to the low likelihood of infringement of rights or freedoms, i.e., a situation where the evaluator may conclude that the risk will not occur at all (i.e., is unlikely to result in risk to the rights and freedoms of natural persons). From this perspective, it is more appropriate to speak of situations: no risk - risk - high risk, whereby the controller or processor assesses the likelihood of risk or high risk.” Such an approach will be true to the extent that the distinction of these three categories will be justified in the interpretation of the GDPR provisions, provided that we accept that (as indicated by the literal wording of the GDPR provisions) low (or no) likelihood of occurrence of an effect in the form of a threat to the infringement of the rights and freedoms of the data subject (as referred to in Article 33(1) GDPR) is equivalent to the absence of risk as such. According to Recital 76 of the GDPR preamble, risk should be assessed based on an objective evaluation, within which it is determined whether the data processing operations involve risk or high risk.

In summary, it should be stated that in the case in question, there is a risk of infringement of the rights or freedoms of the individual subject to the breach, which in turn results in the Company's obligation to notify the supervisory authority of the personal data breach, in accordance with Article 33(1) of Regulation 2016/679, which must include the information specified in Article 33(3) of Regulation 2016/679. It should also be stated that in the present situation, there are no grounds to conclude that the Controller is exempt from the obligation to notify the supervisory authority of the personal data breach in accordance with Article 33(1) of Regulation 2016/679 for any reason. In the circumstances of the examined case, it cannot be reasonably argued that it is unlikely that this breach would result in risk.

violations of the rights or freedoms of the Data Subject. This violation concerned the first name, last name, and mailing address (where it is not indicated by the Company that this address could not also be the place of residence or stay) of the aforementioned person contained in the confirmation of compensation awarded, which also included data regarding the make and model of the car related to the damage, its registration number, and additionally, this document indicated: policy number, claim number, and its value, as well as the amount of the recognized claim. In the opinion of the supervisory authority, there is no justification for the Company's failure to fulfill the obligation arising from the above provision.

In summary of the supervisory authority's comprehensive argumentation, it should be stated that the Administrator - despite updating the circumstances of the analyzed case regarding its obligations - did not report the personal data breach to the supervisory authority in fulfillment of the obligation under Article 33(1) of Regulation 2016/679, which constitutes a violation by the Company of this provision.

According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. The President of UODO states that in the case at hand, there were grounds justifying the imposition of an administrative fine on the Company based on Article 83(4)(a) of Regulation 2016/679, which states, among other things, that a violation of the obligations of the administrator referred to in Article 33 of Regulation 2016/679 is subject to an administrative fine of up to 10,000,000 EURO, and in the case of an enterprise - up to 2% of its total annual worldwide turnover

from the previous financial year, with the higher amount applicable.

Pursuant to Article 83(2) of Regulation 2016/679, administrative fines are imposed, depending on the circumstances of each individual case, in addition to or instead of the measures referred to in Article 58(2)(a) - (h) and (j) of Regulation 2016/679. In deciding to impose an administrative fine on the Company, the President of UODO - in accordance with Article 83(2)(a) - (k) of Regulation 2016/679 - took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which weigh heavily on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679); In this case, a violation of Article 33(1) of Regulation 2016/679 was found (consisting of the failure to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach). This is related to an event involving the disclosure of a document (confirmation of compensation awarded) containing personal data of one individual in the form of: first name, last name, and mailing address, as well as other data regarding the make and model of the car related to the damage, its registration number, and additionally, this document indicated: policy number, claim number, and its value, as well as the amount of the recognized claim. This event may lead to material or non-material damage for the individual whose data has been breached, and the likelihood of such damage occurring is not small.

The President of UODO considers the long duration of the violation by the Company of Article 33(1) of Regulation 2016/679 as an aggravating circumstance. It should be assumed that it has lasted for over seventeen months (the Administrator became aware of the personal data breach no later than May 4, 2022, from the first request for clarification addressed to him by the supervisory authority).

In considering the criterion from Article 83(2)(a) of Regulation 2016/679, it should also be taken into account that the Administrator has additional obligations imposed on him by the previously mentioned Insurance and Reinsurance Activity Act. According to Article 35(1) of this Act, the insurance company and the persons employed by it, as well as the individuals and entities through which the insurance company performs insurance activities, are obliged to maintain confidentiality regarding individual insurance contracts. The processing of a wide range of personal data (on a mass scale and in many cases - although not in this specific one - including data of special categories, such as health data) is inextricably linked to the core activity of the Administrator, namely insurance and claims handling - such a nature of data processing requires the maintenance of specific standards appropriate to the risks associated with it. The gravity of the violation of the regulations should also be considered in the context of these specific circumstances and cannot be deemed insignificant - or that this violation does not have a serious nature.

In this case, the personal data breach concerned only one individual, in the case of whom it was not found that they suffered damage in connection with this violation. In the case considered, the authority recognized these two aspects of the case as mitigating circumstances; however, this did not change the overall assessment, i.e., the recognition in the analyzed case of the criterion from Article 83(2)(a) of Regulation 2016/679 as aggravating.

2. The intentional nature of the violation (Article 83(2)(b) of Regulation 2016/679); According to the Guidelines of the Article 29 Working Party on the application and determination...

****Administrative Monetary Penalties for the Purposes of Regulation No. 2016/679 WP253**** (adopted on October 3, 2017, approved by the EDPB on May 25, 2018), intent "includes both knowledge and deliberate action, in relation to the characteristics of the prohibited act." The Company made a conscious decision not to notify the President of the UODO about the breach. There is no doubt that the Company, processing personal data on a large scale, must have knowledge in the area of personal data protection, including knowledge of the consequences of identifying a personal data breach that results in a risk of infringement of the rights or freedoms of natural persons (and this knowledge can be

required not only from the administrator but also from the data protection officer appointed by them). Being aware of this, the Administrator nevertheless decided to refrain from reporting the breach to the President of the UODO, despite the fact that the President of the UODO initially informed the Company about the obligations imposed on the administrator in connection with the data protection breach, and subsequently initiated administrative proceedings regarding the Company's violation of Article 33(1) of Regulation 2016/679. The mere initiation by the President of the UODO of these proceedings regarding the obligation to report the personal data breach to the supervisory authority should at least raise doubts for the Administrator regarding the correctness of the position adopted by them.

3. Relevant prior violations of the provisions of Regulation 2016/679 by the administrator (Article 83(2)(e) of Regulation 2016/679); The supervisory authority has already established in a previously issued administrative decision (dated (...) February 2022, ref. (...)) a violation by the Administrator of the provisions on personal data protection. This decision was issued in connection with the Company's violation of Article 6(1) of Regulation 2016/679. In light of the above, it should be recognized in this case that there are grounds for treating the criterion in Article 83(2)(e) of Regulation 2016/679 as aggravating.

4. The degree of cooperation with the supervisory authority in order to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). In this case, the President of the UODO deemed the cooperation from the Company to be unsatisfactory. This assessment pertains to the Administrator's response to the letters from the President of the UODO informing about the obligations imposed on the administrator in connection with the data protection breach, or finally regarding the initiation of administrative proceedings concerning the obligation to report the personal data breach. The actions deemed correct by the President of the UODO (reporting the breach to the President of the UODO) were not taken by the Company even after the President of the UODO initiated administrative proceedings in the matter.

In determining the amount of the administrative monetary penalty, the President of the UODO found no grounds to consider mitigating circumstances that would affect the final amount of the penalty. All the criteria listed in Article 83(2)(a) - (j) of Regulation 2016/679, in the opinion of the supervisory authority, constitute either aggravating factors or are merely neutral. Also, applying the criterion mentioned in Article 83(2)(k) of Regulation 2016/679 (requiring consideration of any other aggravating or mitigating factors applicable to the circumstances of the case), the authority found no mitigating circumstances, only neutral ones (as noted below in point 7 regarding financial benefits obtained directly or indirectly in connection with the breach or avoided losses).

Other circumstances, indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified breach in this case, were considered by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty:

1. Actions taken by the administrator to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679); Due to the nature of the breach identified in this case (failure to notify the President of the UODO of the personal data breach without undue delay, no later than 72 hours after its identification) - which breach does not directly relate to the risk of harm to the data subject affected by the personal data breach - it should be accepted that the criterion indicated in Article 83(2)(c) of Regulation 2016/679 has no impact, either aggravating or mitigating, on the amount of the imposed administrative monetary penalty. It is not significant in assessing the Company's violation of Article 33(1) of Regulation 2016/679.

2. The degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by them under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679); Due to the nature of the breach identified in this case (failure to notify the President of the UODO of the personal data breach without undue delay, no later than 72 hours after its identification) - which breach does not relate to the technical and organizational measures applied by the administrator - it should be accepted that the criterion indicated in Article 83(2)(d) of Regulation 2016/679 has no impact, either

aggravating or mitigating, on the amount of the imposed administrative monetary penalty. It is not significant in assessing the Company's violation of Article 33(1) of Regulation 2016/679.

3. Category of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679); Personal data disclosed to an unauthorized person do not belong to the special categories of personal data referred to in Article 9 of Regulation 2016/679, nor do they constitute data concerning criminal convictions and offenses referred to in Article 10 of that Regulation. However, in this case, the authority considered that this circumstance cannot be a mitigating factor in the amount of the imposed administrative fine. A breach of data protection of any category must be automatically assessed negatively, as it constitutes a violation of the provisions of Regulation 2016/679. The fact that the disclosed document (confirmation of damage awarded) contained the first and last name, mailing address of one person along with a number of other data concerning the policy, car, and the damage that occurred to it, is associated with the risk of infringing the rights or freedoms of natural persons—therefore, in this case, there are no grounds for mitigating the amount of the administrative fine due to the fact that the data affected by the breach of personal data protection are not data of the aforementioned categories.

4. The manner in which the supervisory authority became aware of the breach (Article 83(2)(h) of Regulation 2016/679); The President of the UODO was informed by a third party about the occurrence of the breach of Article 33(1) of Regulation 2016/679 related to the event involving the disclosure by the Administrator of a document containing personal data to an unauthorized recipient. The lack of notification to the supervisory authority of the breach of personal data protection is the sole subject of these proceedings, and in the circumstances of the considered factual state, the supervisory authority accepted that it would not treat this circumstance as an aggravating factor.

5. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679); Prior to issuing this decision, the President of the UODO did not apply any measures against the Administrator in the case under consideration as mentioned in Article 58(2) of Regulation 2016/679, which means that the Administrator had no obligation to take any actions related to their application, and such actions, assessed by the President of the UODO, could have an aggravating or mitigating effect on the assessment of the established breach.

6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679); The Administrator does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for administrators and processors, as stipulated by the provisions of Regulation 2016/679, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as means guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Administrator.

7. Financial benefits obtained directly or indirectly in connection with the breach or avoided losses (Article 83(2)(k) of Regulation 2016/679); The President of the UODO did not find that the Administrator obtained any financial benefits or avoided such losses in connection with the breach. Therefore, there are no grounds to treat this circumstance as aggravating for the Administrator. The establishment of measurable financial benefits resulting from the breach of the provisions of Regulation 2016/679 should be assessed decidedly negatively. However, the failure of the Administrator to achieve such benefits, as a natural state independent of the breach and its effects, is a circumstance that, by its nature, cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained"—arising on the part of the entity committing the breach.

In the opinion of the President of the UODO, the imposed administrative fine fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportionate, and deterrent in this individual case. It should be emphasized that the fine will

be effective if its imposition leads to the Company, which processes personal data professionally and on a large scale, fulfilling its obligations regarding personal data protection in the future, particularly in terms of reporting breaches of personal data protection to the President of the UODO.

In the opinion of the President of the UODO, the administrative fine will serve a repressive function, as it will constitute a response to the Company's violation of the provisions of Regulation 2016/679. It will also serve a preventive function; in the opinion of the President of the UODO, it will indicate to both the Company and other data controllers the reprehensibility of neglecting the obligations of controllers related to the occurrence of a breach of personal data protection, which are aimed at preventing its negative and often severe consequences for the individuals affected by the breach, as well as removing those consequences or at least limiting them.

In accordance with the provisions of Article 103 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781), hereinafter referred to as "uodo," the equivalent expressed in euros of the amounts referred to in Article 83 of Regulation 2016/679 is calculated in zlotys according to the average euro exchange rate announced by the National Bank.

Polish in the exchange rates table as of January 28 of each year, and in the event that in a given year the National Bank of Poland does not announce the average exchange rate of the euro on January 28 - according to the average exchange rate of the euro announced in the nearest exchange rates table of the National Bank of Poland after that date.

Having this in mind, the President of the UODO, based on Article 83(4)(a) in conjunction with Article 103 of the UODO, for the violation described in the operative part of this decision, imposed on the Company - applying the average exchange rate of the euro from January 30, 2023 (1 EUR = 4.7160 PLN) - an administrative monetary penalty in the amount of 103,752 PLN (which is equivalent to 22,000 EUR).

In the opinion of the President of the UODO, the imposed monetary penalty of 103,752 PLN (in words: one hundred three thousand seven hundred fifty-two zlotys) meets the criteria mentioned in Article 83(1) of Regulation 2016/679 due to the seriousness of the established violation in the context of the fundamental purpose of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data. Referring to the amount of the administrative monetary penalty imposed on the Company, the President of the UODO considered that it is proportional to the financial situation of the Administrator and will not constitute an excessive burden for him. The financial report presented by the Administrator shows that the amount of gross premiums assigned in 2022 amounted to (...),- PLN, which means that the amount of the administrative monetary penalty imposed in this case constitutes approximately (...)% of the aforementioned revenue amount. At the same time, it is worth emphasizing that the amount of the imposed penalty of 103,752 PLN is only 0.22% of the maximum amount of the penalty that the President of the UODO could - applying in accordance with Article 83(4) of Regulation 2016/679 the static maximum penalty (i.e. 10,000,000 euros) - impose on the Company for the violation established in this case.

The amount of the penalty was determined at such a level that, on the one hand, it constitutes an adequate response of the supervisory authority to the degree of violation of the Administrator's obligations, while on the other hand, it does not lead to a situation in which the necessity to pay the financial penalty would result in negative consequences, in the form of significant reductions in employment or a substantial decrease in the Company's turnover. In the opinion of the President of the UODO, the Company should and is able to bear the consequences of its negligence in the area of data protection, as evidenced by the financial report of the Company submitted to the President of the UODO on July 28, 2023.

In this factual and legal state, the President of the Office for Personal Data Protection decided as stated in the operative part.

[1] Guidelines of the Article 29 Working Party on reporting personal data breaches in accordance with Regulation 2016/679 (WP250rev.01), hereinafter referred to as WP250 Guidelines.

[2] Guidelines of the European Data Protection Board on reporting personal data breaches, version 2.0, hereinafter referred to as Guidelines 9/2022.

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Information created by:

Jan Nowak

2023-10-18

Information entered by:

Wioletta Golańska

2023-12-06 13:33:09

Last modified by:

Edyta Madziar

2023-12-07 09:16:54